

```

(root@kali)-[/home/kali/Desktop]
# gobuster dir -u http://192.168.10.137/ -w /usr/share/wordlists/dirb/big.txt

Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.10.137/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/big.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/.htaccess (Status: 403) [Size: 319]
/.htpasswd (Status: 403) [Size: 319]
/backup (Status: 301) [Size: 357] [→ http://192.168.10.137/backup/]
/server-status (Status: 403) [Size: 319]
/uploads (Status: 301) [Size: 358] [→ http://192.168.10.137/uploads/]
Progress: 20469 / 20470 (100.00%)

Finished

```

```

(root@kali)-[/home/kali]
# nmap -p- -sS -T4 -v 192.168.10.137
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-27 09:41 EDT
Initiating Ping Scan at 09:41
Scanning 192.168.10.137 [4 ports]
Completed Ping Scan at 09:41, 0.03s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 09:41
Completed Parallel DNS resolution of 1 host. at 09:41, 6.52s elapsed
Initiating SYN Stealth Scan at 09:41
Scanning 192.168.10.137 [65535 ports]
Discovered open port 110/tcp on 192.168.10.137
Discovered open port 25/tcp on 192.168.10.137
Discovered open port 143/tcp on 192.168.10.137
Discovered open port 80/tcp on 192.168.10.137
Discovered open port 22/tcp on 192.168.10.137
SYN Stealth Scan Timing: About 19.86% done; ETC: 09:43 (0:02:05 remaining)
SYN Stealth Scan Timing: About 40.93% done; ETC: 09:43 (0:01:28 remaining)
SYN Stealth Scan Timing: About 68.86% done; ETC: 09:43 (0:00:41 remaining)
Completed SYN Stealth Scan at 09:43, 112.26s elapsed (65535 total ports)
Nmap scan report for 192.168.10.137
Host is up (0.00017s latency).
Not shown: 65530 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    open  ssh
25/tcp    open  smtp
80/tcp    open  http
110/tcp   open  pop3
143/tcp   open  imap

Read data files from: /usr/share/nmap
Nmap done: 1 IP address (1 host up) scanned in 118.95 seconds
Raw packets sent: 131152 (5.770MB) | Rcvd: 179418 (11.440MB)

```

先扫一下

PHP Version 8.4.24	
System	Linux Tftpy 7.2.7-1-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.2-12.2-trixie (2026-09-22) x86_64
Build Date	Jul 31 2026 05:11:11
Build System	Linux
Build Provider	Debian
Server API	Apache 2 Handler
Virtual Directory Support	disabled
Configuration File (php.ini) Path	/etc/php/8.4/apache2
Loaded Configuration File	/etc/php/8.4/apache2/php.ini
Scan this dir for additional .ini files	/etc/php/8.4/apache2/conf.d
Additional .ini files parsed	/etc/php/8.4/apache2/conf.d/10-opcache.ini, /etc/php/8.4/apache2/conf.d/10-pdo.ini, /etc/php/8.4/apache2/conf.d/20-calendar.ini, /etc/php/8.4/apache2/conf.d/20-ctype.ini, /etc/php/8.4/apache2/conf.d/20-exif.ini, /etc/php/8.4/apache2/conf.d/20-ffi.ini, /etc/php/8.4/apache2/conf.d/20-fileinfo.ini, /etc/php/8.4/apache2/conf.d/20-ftp.ini, /etc/php/8.4/apache2/conf.d/20-gettext.ini, /etc/php/8.4/apache2/conf.d/20-iconv.ini, /etc/php/8.4/apache2/conf.d/20-phar.ini, /etc/php/8.4/apache2/conf.d/20-posix.ini, /etc/php/8.4/apache2/conf.d/20-readline.ini, /etc/php/8.4/apache2/conf.d/20-shmop.ini, /etc/php/8.4/apache2/conf.d/20-sockets.ini, /etc/php/8.4/apache2/conf.d/20-sysmsg.ini, /etc/php/8.4/apache2/conf.d/20-sysvsem.ini, /etc/php/8.4/apache2/conf.d/20-sysvshm.ini, /etc/php/8.4/apache2/conf.d/20-xml.ini, /etc/php/8.4/apache2/conf.d/20-xmlrpc.ini

80 端口是一个 phpinfo
没看出东西

国内版

国际版

🔍

tftp是什么

🔊

网页

图片

视频

学术

词典

地图

航班



约 12,400 个结果

🔄

👍

💬

TFTP（Trivial File Transfer Protocol）是一种基于UDP的轻量级文件传输协议，用于在客户端与服务器之间进行小文件的简单传输。

基本概念

TFTP是TCP/IP协议族中的 一种简单文件传输协议 主要应用于小文件传输 端口号是69
搜了一下主机名，是基于 UDP 的，nmap 没扫

```
(root@kali)-[/home/kali/Desktop]
# nmap -Pn -sU -p 69 --reason 192.168.10.137
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-27 10:05 EDT
Nmap scan report for 192.168.10.137
Host is up, received user-set.

PORT      STATE      SERVICE REASON
69/udp    open|filtered tftp    no-response

Nmap done: 1 IP address (1 host up) scanned in 8.72 seconds
```

69 端口有

语法

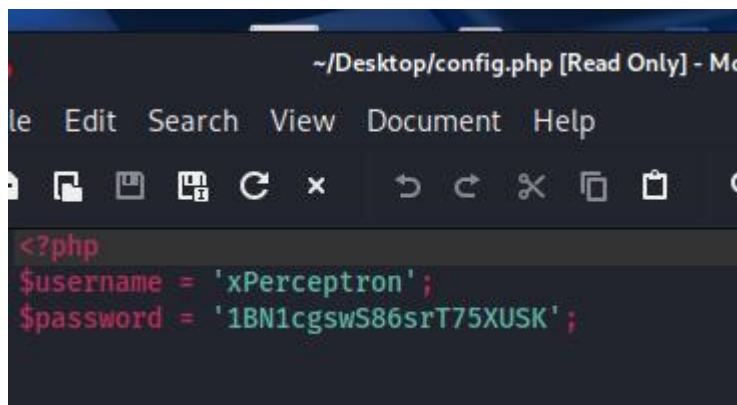
```
tftp [选项] [主机名或IP地址]
```

常用选项:

tftp 命令支持一些常用的选项，以下是一些常见的选项及其作用。

- -v: 启用详细模式，显示更多的调试信息。
- -c: 指定要传输的文件。
- -l: 指定本地文件名。
- -r: 指定远程文件名。
- -g: 从服务器获取文件（等同于get命令）。
- -p: 将文件上传到服务器（等同于put命令）。

可以直接获取文件？但是 tftp 看不到有哪些文件

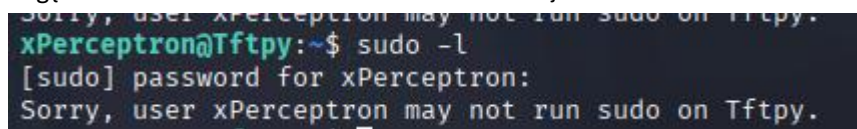


```
~/Desktop/config.php [Read Only] - Me...
File Edit Search View Document Help
[Icons]
<?php
$username = 'xPerceptron';
$password = '1BN1cgswS86srT75XUSK';
```

get config.php 发现了一个账号密码

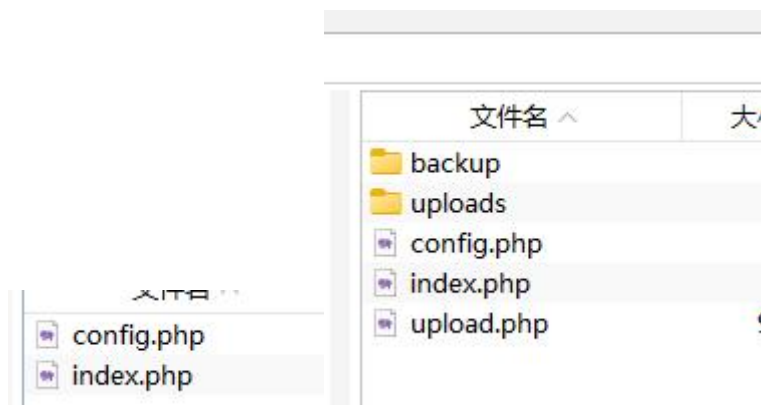
拿去能 ssh 连上

flag{user-25a12ecfe27b8ca6f910a5ee41134cb9}



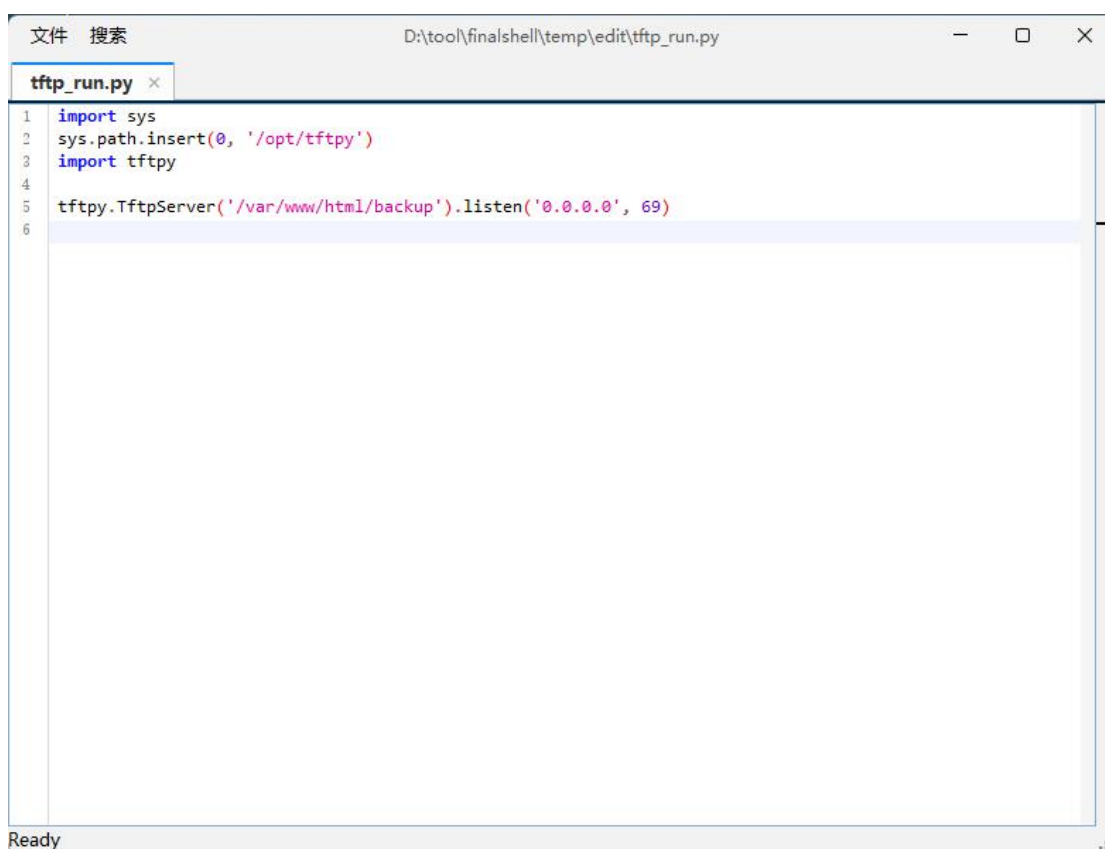
```
Sorry, user xPerceptron may not run sudo on Tftpy.
xPerceptron@Tftpy:~$ sudo -l
[sudo] password for xPerceptron:
Sorry, user xPerceptron may not run sudo on Tftpy.
```

这个不行



可以发现备份比现在运行的少了一个 upload.php

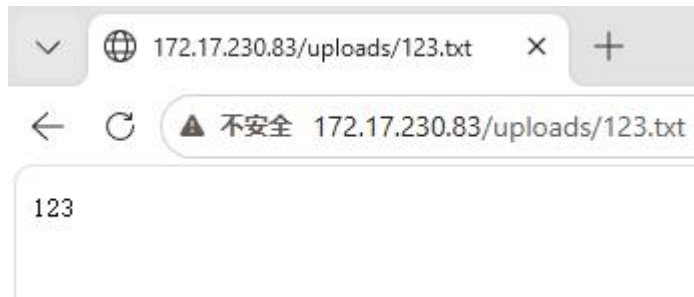
```
xPerceptron@Tftpy:~$ ps aux | grep tftp
root      389   0.0  0.8 23972 17384 ?        Ss   20:30   0:00 /usr/bin/python3 /opt/tftpy/run.py
xPercep+ 38501  0.0  0.0   656   180 pts/0    R+   21:28   0:00 grep tftp
```



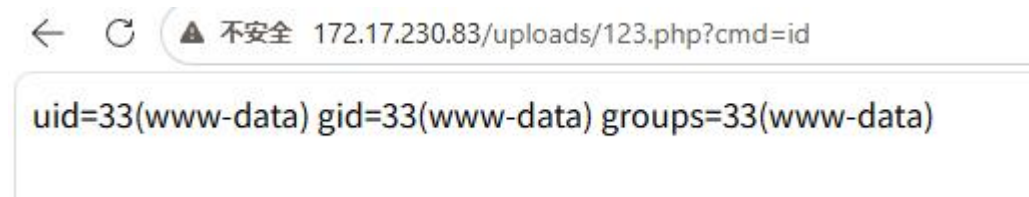
tftp 是以 root 运行的，但是他只能读取 backup 里面的文件，直接读取 root.txt 会失败，但是我没法往 backup 里写文件

```
xPerceptron@Tftpy:/var/www/html/uploads$ nano 123.txt
xPerceptron@Tftpy:/var/www/html/uploads$ ls
123.txt
xPerceptron@Tftpy:/var/www/html/uploads$
```

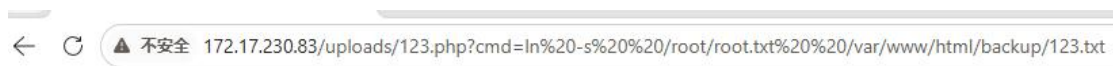
往 uploads 里面写一个 123.txt



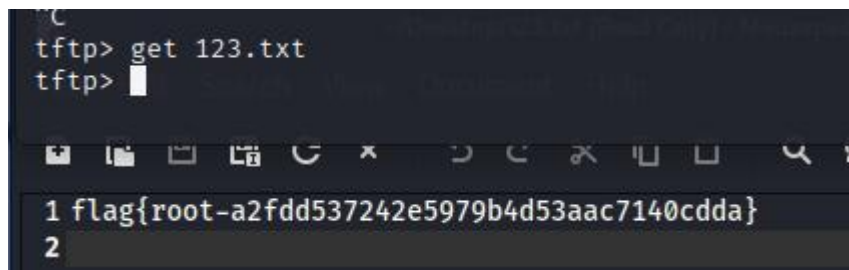
可以访问



往里面写入木马就拿到了他的 webshell



往 backup 里面写一个链接指向 root.txt



就能拿到 flag 了

flag{root-a2fdd537242e5979b4d53aac7140cdda}